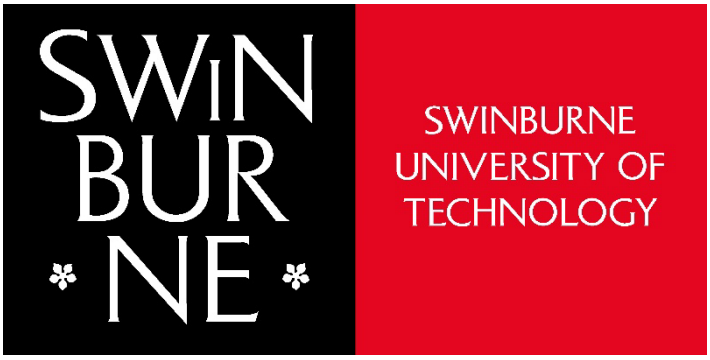


Unit Code: COS30049

Unit Name: Computing Technology Innovation Project

Sprint 1 Report

Members:

Name	**Student ID**
Amberlyn Xi En LIM	104391342
Albian Pang SEO	104392785
Michelle Mei Xuan TAN	104394341
Nicole Jia Xin TAN	104406767
Norman Zhi Wen CHUNG	104387930
Patrick Lip Siang SIM	104393720
Ricardo Zhen Wei CHEW	104392756

Table of Contents

Table of Contents i
List of Figures i
List of Tables i
1 Sprint Plan 1
1.1 Sprint Goal 1
1.2 Sprint Duration 1
1.3 Sprint Backlog Items 1
1.4 Activities and Work Breakdown Structure 3
1.5 Jira Board 4
2 Sprint Review 5
2.1 Statuses and Remarks on Completed Items 5
2.2 Summary of Completed Work 7
2.3 Challenges Encountered 9
2.4 Jira Burndown Chart 11
3 Sprint Retrospective 12
3.1 What Went Well 12
3.2 What Could Be Improved 12
4 Sprint Deliverables 13
4.1 Current deliverables of Sprint 1 13

List of Figures

Figure 1: Sprint 1 work breakdown structure (story points in brackets) 3
Figure 2: Jira Board 4
Figure 3: Sprint 1 burndown, 28 September to 13 October 2026 11

List of Tables

Table 1: Sprint 1 at a glance 1
Table 2: Sprint 1 backlog 2
Table 3: Sprint 1 activities by workstream 4
Table 4: Status and remarks for each Sprint 1 item at sprint close (14 October 2026) 7
Table 5: Story points by status at sprint close (14 October 2026) 8
Table 6: Sprint 1 deliverables 14

1 Sprint Plan

1.1 Sprint Goal

Sprint 1 was planned as a foundation sprint. Its purpose was to set up the shared platform that every other workstream depends on. This includes creating the OpenAPI contract and the Supabase database. Besides that, part of the goals is the creation of the four system components (the Botanist Field App, the Digital Plant Knowledge System, the security layer and the IoT plant protection node), and to complete the first "assess" step of the Secure Software Development Life Cycle (SSDLC) through threat modelling.

1.2 Sprint Duration

Sprint 1 ran for two weeks, as summarised in Table 1.

Item	Detail
Sprint	CTIP Sprint 1 (Jira board for project CTIP)
Start date	Monday, 28 September 2026
End date	Sunday, 11 October 2026
Length	2 weeks
Framework	Scrum, tracked in Jira
Team	7 members: Albian (Product Owner), Nicole (Scrum Master), Amberlyn, Michelle, Norman, Patrick and Ricardo. All seven also work as developers.
Commitment	12 estimated stories (64 story points), 4 subtasks under CTIP-14, and 1 unestimated story(CTIP-52)

Table 1: Sprint 1 at a glance

1.3 Sprint Backlog Items

Table 2 lists the items committed to Sprint 1, grouped by epic. Every story was written with acceptance criteria in Jira, and the stories affected by the online-first directive carry a scope note explaining the change.

Key	Item	Epic	Owner	Priority	Points
CTIP-13	API Foundation: OpenAPI contract skeleton	Platform & API Foundation	Amberlyn	High	5
CTIP-25	Supabase database schema and storage setup	Platform & API Foundation	Amberlyn	High	5
CTIP-49	QA: CI pipeline and automated test setup	Platform & API Foundation	Michelle	Medium	3
CTIP-14	Auth and RBAC middleware (subtasks CTIP-40 to CTIP-43)	Cybersecurity & SSDLC	Nicole	High	13
CTIP-18	Security: threat modelling	Cybersecurity & SSDLC	Michelle	Medium	3
CTIP-36	Security: vulnerability assessment test plan	Cybersecurity & SSDLC	Michelle	Medium	3
CTIP-15	Mobile: specimen capture (online-first) with QR, photo and GPS	Mobile Ground-Truthing App	Patrick	Medium	8
CTIP-26	Mobile: plant species lookup and search	Mobile Ground-Truthing App	Albian	Medium	5
CTIP-27	Mobile: QR code generation for plant records	Mobile Ground-Truthing App	Albian	Medium	3
CTIP-28	Web: species record management (CRUD and photos)	Web Plant Knowledge System	Ricardo	Medium	5

CTIP-17	IoT: ESP32 firmware and MQTT ingestion	IoT Plant Protection	Norman	Medium	8
CTIP-47	IoT: sensor simulator and telemetry storage	IoT Plant Protection	Norman	Medium	3
CTIP-52	ER Diagram	None	Amberlyn	Medium	–
CTIP-54	Connect the Express API to the frontend	None	Nicole	Medium	–

Table 2: Sprint 1 backlog

CTIP-14 (Auth and RBAC, 13 points) is the largest item. It was split into four subtasks so it could be shared across streams: CTIP-40 backend authentication with Supabase Auth and JWT, and CTIP-41 backend RBAC and tests (both Nicole), CTIP-42 the mobile app shell and login screen (Patrick), and CTIP-43 the web login page and role-based layouts (Ricardo). CTIP-52 (ER diagram) was added on 5 October and CTIP-54 (connecting the Express API to the frontend) on 12 October, so neither counts towards the 64 committed points. On 13 October, after the sprint, CTIP-14 was rescoped to the backend only (8 points), and CTIP-42 (3 points) and CTIP-43 (2 points) became stories in their own right, so the three still add up to 13 points. CTIP-54 was rewritten the same day as a shared API client for the web and mobile apps and moved to Sprint 2.

1.4 Activities and Work Breakdown Structure

The work was broken down from the project epics into stories and, where a story spanned several people, into subtasks (Figure 1). Each story points to one of seven workstreams, and each workstream has a single owner, as agreed by the team on 28 September 2026.

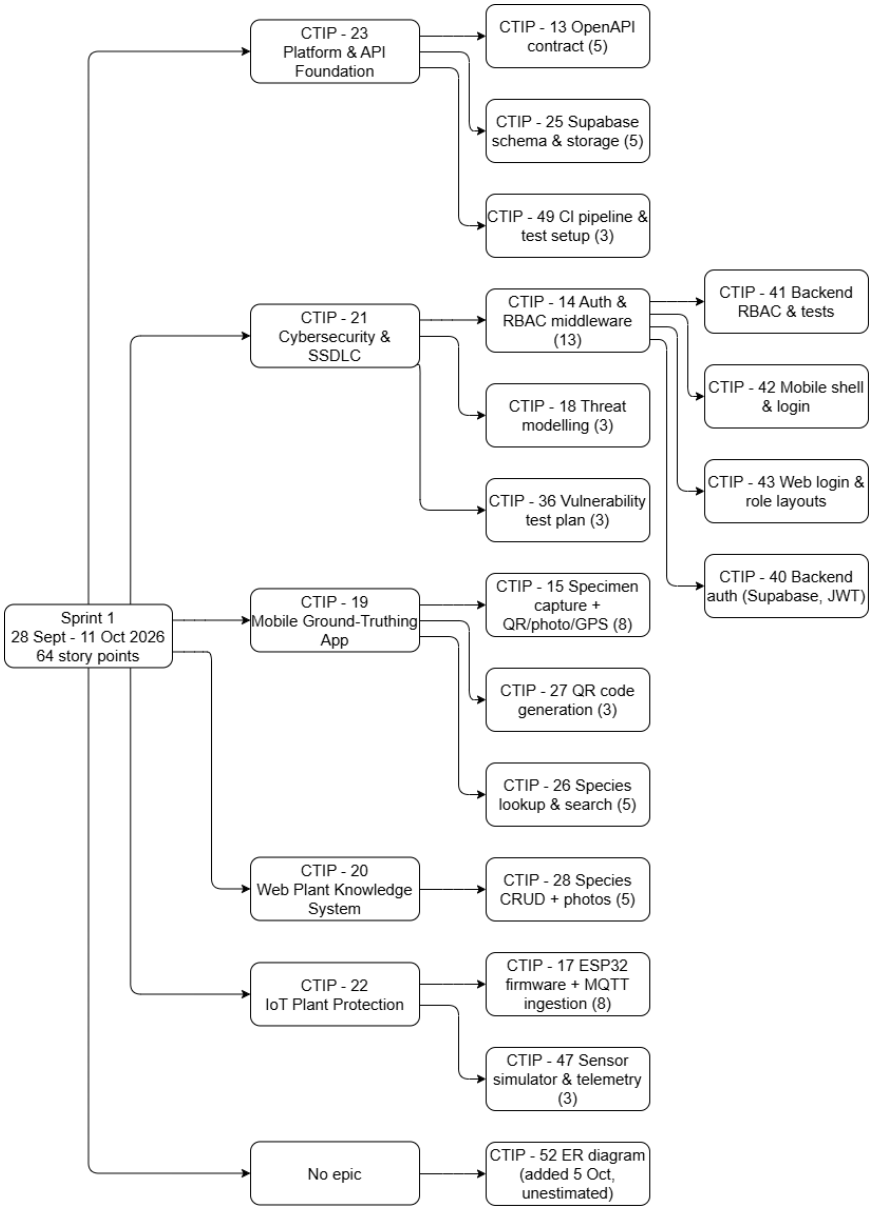


Figure 1: Sprint 1 work breakdown structure (story points in brackets)

Table 3 maps the Sprint 1 activities to each workstream and owner.

Workstream	Owner	Sprint 1 activities	Jira items
A. Mobile app UI	Patrick	App shell and login screen; specimen capture with QR binding, photo and GPS	CTIP-42, CTIP-15
B. Mobile data and offline	Albian	Online species lookup and search; QR code generation as a fallback for missing pre-printed tags. Also Product Owner: Jira backlog and sprint setup, repository structure and contribution conventions	CTIP-26, CTIP-27
C. Backend API and database	Amberlyn	OpenAPI contract; Supabase schema, row-level security and storage buckets; ER diagram	CTIP-13, CTIP-25, CTIP-52

D. Web knowledge system	Ricardo	Web login and role-based layouts; species record management with photos	CTIP-43, CTIP-28
E. IoT and anomaly detection	Norman	ESP32 firmware and MQTT ingestion; sensor simulator and telemetry storage	CTIP-17, CTIP-47
F. Security architecture	Nicole	Supabase Auth with JWT; role-based access control middleware. Also Scrum Master	CTIP-14, CTIP-40, CTIP-41
G. Security testing and QA	Michelle	Threat model; vulnerability assessment test plan; CI pipeline and test setup	CTIP-18, CTIP-36, CTIP-49

Table 3: Sprint 1 activities by workstream

Two planning rules shaped the breakdown:

- **Contract first.** Stream C is the early bottleneck because the mobile app, the web app and the API all build on the OpenAPI contract and the database schema. Streams A, B and D were told to build against sample data until the contract landed.
- **Separation of duties.** Security implementation (stream F) and security testing (stream G) were given to different people, so that nobody tests their own code. Testing finds the issues and implementation fixes them.

1.5 Jira Board

Figure 2 shows the Sprint 1 board at sprint close on 14 October 2026. It was drawn from the issue data on the CTIP Jira board, after each status had been checked against what was merged into main and the large stories had been split on 13 October (Section 2.2).

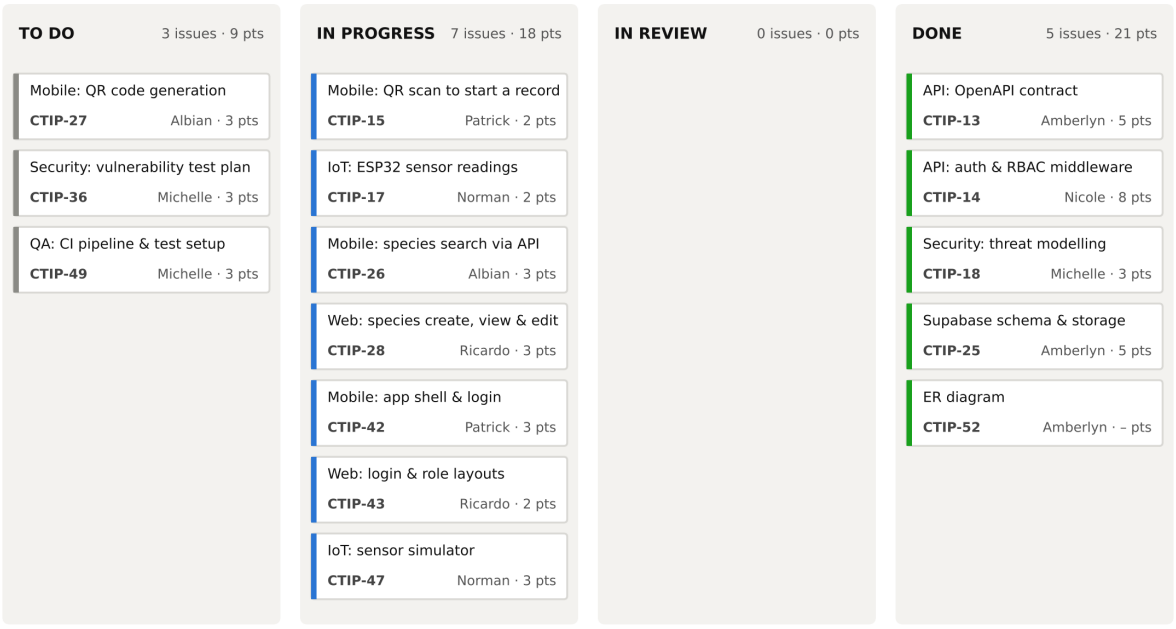


Figure 2: Jira Board

Of the 15 items on the board, 5 are Done (21 points), 7 are In Progress (18 points) and 3 are still To Do (9 points); none is In Review. CTIP-42 and CTIP-43 now appear as stories, CTIP-15, CTIP-17, CTIP-26 and CTIP-28 show only the slice that stays in Sprint 1, and CTIP-54 has moved to Sprint 2.

2 Sprint Review

2.1 Statuses and Remarks on Completed Items

Table 4 gives the Jira status of every Sprint 1 item, with remarks on what has been produced.

Key	Item	Status	Remarks
CTIP-18	Threat modelling	Done	Threat model updated to v0.4 and merged into main (PRs #1, #3, #8 and #9), with a revised data flow diagram (v4) marking trust boundaries. It now identifies 25 threats using STRIDE (2 Critical, 14 High, 8 Medium, 1 Low), adding email-login risks such as account takeover through a hacked mailbox and fake sign-ups. It proposes fix tickets for the mitigations that need code and maps every threat to a test idea for CTIP-36.
CTIP-13	OpenAPI contract	Done	Contract merged into main on 8 October: 39 paths and 55 operations, validating with Redocly with no errors. The API's route permissions (CTIP-41) cover every operation in it. Moved to Done on 12 October, but two acceptance criteria are still open: create endpoints do not yet accept a client-generated idempotency key, and the contract has not had its two-reviewer approval.
CTIP-25	Supabase schema and storage	Done	Nine migrations on main, applied to the shared Supabase project: 16 tables, row-level security on every table, audit and notification triggers, an approval function, three storage buckets and, from 12 October, the hook that adds each user's role to their login token. A reset script lets the migrations be rerun on a clean database. Moved to Done on 12 October; the seed script with sample Niah species is still outstanding.
CTIP-14	Auth and RBAC middleware (API)	Done	Rescoped on 13 October to the backend only and re-estimated from 13 to 8 points. PR #12 (merged 12 October) delivered the Express API with Supabase token checks (CTIP-40) and role checks on all 55 operations, with 13 automated tests running in CI (CTIP-41); every backend acceptance criterion is met. The mobile and web login subtasks became stories CTIP-42 and CTIP-43.

CTIP-52	ER diagram	Done	Added on 5 October and moved to Done on 12 October. The entity-relationship diagram of the Supabase database is committed to the repository under docs/architecture/.
CTIP-54	Shared API client for web and mobile	Moved to Sprint 2	Added on 12 October as "Connect the Express API to the frontend" and moved to In Review with no pull request open. Rewritten on 13 October, because sign-in (CTIP-42, CTIP-43) and each feature's own API calls already have stories: it is now a 2-point shared API client (token handling, refresh and retry, consistent errors) and the first job in Sprint 2.
CTIP-42	Mobile app shell and login	In Progress	Split out of CTIP-14 on 13 October (3 points). The app shell and login screen are on main (PR #11), but sign-in still uses sample data. Still to do: sign in through Supabase Auth, cache the session and revalidate it on reconnect, refresh expired tokens.
CTIP-43	Web login and role-based layouts	In Progress	Split out of CTIP-14 on 13 October (2 points). The login page and a layout per role are on main (PRs #7 and #10), but sign-in still uses sample data. Still to do: sign in through Supabase Auth, route each role from its token, refresh expired tokens.
CTIP-15	QR scan to start or open a record	In Progress	Cut on 13 October from 8 points to the QR scanning slice (2 points); photos, GPS, crash-safe draft and submit moved to Sprint 2 as CTIP-55 to CTIP-58. The mobile prototype (PR #11) scans QR tags with the phone camera, but tag lookup and binding still use sample data.
CTIP-17	ESP32 sensor readings and wiring	In Progress	Cut on 13 October from 8 points to the sensor-reading slice (2 points); motion detection, MQTT/TLS publishing, the MQTT bridge and webcam images moved to Sprint 2 as CTIP-59 to CTIP-62. The server side was merged on 8 October (PRs #4 and #5), but the firmware itself has still not been committed.

CTIP-26	Mobile species search via API	In Progress	Cut on 13 October from 5 to 3 points; pre-filling a record from a result moved to Sprint 2 as CTIP-63. The mobile Species page (PR #11) searches with partial matching on sample data. The API currently lets only officers and admins read GET /species, so botanist access needs to be decided (CTIP-87).
CTIP-28	Web species create, view and edit	In Progress	Cut on 13 October from 5 to 3 points; photo upload and soft delete moved to Sprint 2 as CTIP-64 and CTIP-65. Species catalogue, species and specimen pages are on main (PRs #7 and #10) on sample data. Still to do: connect them to the API so edits are enforced by role on the server.
CTIP-47	Sensor simulator and telemetry storage	In Progress	Telemetry storage is ready in the database. The Python simulator has not yet been committed (services/anomaly-detection is empty).
CTIP-27	Mobile QR generation	To Do	Not started on mobile. The web prototype already renders QR codes for tags, and that approach can be reused. Carries over.
CTIP-36	Vulnerability assessment test plan	To Do	No standalone plan yet (docs/testing is empty). Section 6 of the threat model maps each threat to a test idea and will form its basis. Must land first in Sprint 2, because the assessment runs at the start of that sprint.
CTIP-49	CI pipeline and test setup	To Do	CI now runs two jobs on every pull request: web lint and build, and the API tests added under CTIP-41. Main requires one approving review. Still outstanding: mobile and anomaly-detection jobs, npm audit evidence, CI as a required check on main, and a testing guide.

Table 4: Status and remarks for each Sprint 1 item at sprint close (14 October 2026)

2.2 Summary of Completed Work

By story points, Sprint 1 completed 21 of the 64 committed points (33%): CTIP-13, CTIP-14, CTIP-18 and CTIP-25 are Done, and the unestimated CTIP-52 is also Done. At the planned end on 11 October only 3 points were Done; CTIP-13 and CTIP-25 closed at the sprint review on 12 October, and CTIP-14 on 13 October once it was rescoped to its finished backend work. On 13 October the large stories were also split, and 16 points of split-out work moved to Sprint

2. Table 5 shows where the 64 committed points now sit. When the sprint was closed in Jira on 14 October, the 10 unfinished stories (27 points) were carried over to Sprint 2.

Status	Items	Story points	Share of commitment
Done	5	21	33%
In Review	0	0	0%
In Progress	7	18	28%
To Do	3	9	14%
Moved to Sprint 2 (split-out work, CTIP-54)	–	16	25%
Total	**15**	**64**	**100%**

Table 5: Story points by status at sprint close (14 October 2026)

The main outcomes of the sprint were:

- **The team has agreed to use the same platform for building project.** The API contract and the database schema were merged into main in github on 8 October, and the schema is live in the team's Supabase project with row-level security on every table. Mobile, web, auth and IoT work now build against one agreeable data model.
- **The SSDLC assess step has been completed.** The team has completed the security risk assessment. The team identified a security risk, **T23**, where an attacker could try to access the database directly using a public key instead of going through the API. On 8 October, the team also discovered a real security flaw: a user could call an approval function without logging in, and the system failed to block the request when the user's role was missing. The team fixed the security issue on the same day by updating the database settings and confirmed that the fix worked on the live database. After the fix, Supabase's security warnings dropped from 20 to 3. The team has also reviewed the three remaining warnings and understands what they meant.
- **The API layer has been tested successfully.** The Express API was added to the main GitHub branch on 12 October. It checks whether every Supabase login token is valid, retrieves the user's role directly from the database instead of trusting information sent in the request, and ensures that only users with the correct permissions can perform any of the 55 available operations. The team also created 13 automated tests to check user permissions, expired or fake login tokens, and incorrectly formatted requests. These tests run automatically whenever someone submits a pull request on GitHub.
- **Assign smaller stories point in Jira.** On 13 October, the team broke down 13 large tasks into 47 smaller tasks, each estimated at no more than 3 story points. Every task now has clear conditions for completion and a person responsible for it. This makes the

work easier to manage and track, allowing the team to see its progress more clearly on the burndown chart starting from Sprint 2.

- **Web and mobile prototypes demonstrate the system's features for every user role.** The web prototype was merged into the main GitHub branch on 8 October and later expanded to include species catalogue and specimen pages. A matching mobile prototype, built with Expo and featuring camera-based QR code scanning, was merged on 12 October. Both prototypes currently use sample data, but their data-handling functions are designed to be replaced with API calls later. This allows the team to demonstrate and test the user interface before connecting it to the actual backend.
- **The team has established rules and tools to help everyone work together safely and consistently.** The GitHub repository has a clear folder structure, a README explaining the project, and guidelines for contributing code. Each developer must create a separate branch for their Jira task and submit a pull request for review before merging changes. Changes to the API contract require two approvals. The team has also set up a Supabase CLI workflow for managing database changes and an automated CI workflow for checking code. In addition, the main branch now requires at least one approval before changes can be merged. These practices help the team coordinate development, review changes and reduce the risk of introducing errors.
- **All contributions have been made & recorded.** Between 28 September and 11 October, 59 commits were added to the main GitHub branch, followed by another 13 commits on 12 October. The team merged 11 pull requests, with 9 completed during the sprint period. All feature branches have also been merged or closed, meaning no feature branches remain open. This shows that the team has been regularly integrating its work instead of leaving changes unfinished in separate branches.

2.3 Challenges Encountered

- **Several development tasks were delayed because they depended on the API contract and database structure.** These shared foundations were not merged into the main GitHub branch until 8 October. Before that, the web app had to use sample data instead of the actual backend, the authentication middleware had no agreed API operations to protect, and work on the mobile app had not yet started. As a result, progress across several parts of the project was held back by the late completion of these shared components.
- **Unfamiliar with frameworks and technology.** Most team members were unfamiliar with React, React Native with Expo, Supabase and MQTT. As a result, the team had to spend a considerable amount of time learning how these technologies work and setting up the development environment before making significant progress on the project.
- **Using one shared live database.** Currently Docker is not available on the team's machines, so there is no local database and every migration goes straight to the shared Supabase project. The team also discovered a database function on 8 October that had been created outside the usual migration process, likely through Supabase's SQL Editor. The team then removed it to keep database changes managed through the proper migration files.

- **A security defect has been found in the live database.** The approval function described under Summary of Completed Work could be called without signing in. It was caught in review before any client was connected and it was fixed in the same day.
- **Most works were concentrated at the end on Sprint 1.** Out of 27 of the sprint's, 41 commits were made on 7 October, leaving little time for review and integration before sprint closes.
- **The team did not always follow the agreed development process.** Some Git branches were created without using the required Jira task number in their names, and some code changes were merged into the main branch without being reviewed through a pull request. The Jira task board also did not always reflect the actual progress in GitHub. For example, CTIP-17 was marked as completed but later reopened, and its current status is “In Review” even though no code has been committed for it. This shows that the team needs to improve how it follows development procedures and keeps Jira task statuses aligned with actual coding progress.
- **Web & mobile integration mismatches.** The web prototype uses a different name for the officer role from the database, and the contract does not yet carry the idempotency key. Both were found during review and are scheduled to be fixed.
- **Frequent changes to the project structure and tools disrupted development**. On 7 October, the team removed the shared front-end packages, moved the Supabase folder to the repository's root directory, and switched firmware development from PlatformIO to the Arduino IDE. These changes required team members to adapt to the new project structure and tools, potentially causing setup issues and interrupting ongoing work.

2.4 Jira Burndown Chart

Figure 3 presents the Sprint 1 burndown chart generated from Jira for the period 28 September to 11 October 2026. The chart tracks the number of remaining work items throughout the sprint against the ideal burndown guideline.



Figure 3: Sprint 1 burndown, 28 September to 13 October 2026

The burndown chart shows very limited progress during most of the sprint, with the remaining work staying close to the initial commitment level. Several scope changes occurred during the sprint, including the addition of CTIP-52 ER Diagram on 5 October and CTIP-54 API: Shared API Client for Web & Mobile on 12 October. On 13 October, CTIP-42 Mobile: App Shell & Login and CTIP-43 Web: Login & Role-Based Layouts were added to the sprint, while CTIP-54 was removed. These changes increased the overall sprint commitment by three work items.

By the end of the sprint, only five work items had been completed: CTIP-13 API Foundation: OpenAPI Contract Skeleton, CTIP-14 API: Auth & RBAC Middleware, CTIP-25 Supabase Database Schema & Storage Setup, CTIP-18 Security: Threat Modelling, and CTIP-52 ER Diagram. Several planned stories remained in progress or not started, resulting in the actual burndown curve remaining significantly above the ideal guideline.

The chart highlights that work was concentrated toward the latter part of the sprint and that a large proportion of stories were not completed within the planned timeframe. This indicates a need for smaller, more manageable user stories and earlier completion of deliverables to achieve a steadier burndown rate in future sprints.

3 Sprint Retrospective

3.1 What Went Well

- **Clear ownership:** Seven workstreams with one owner each meant every story had a clear owner, and security implementation and security testing were assigned to different people from the start.
- **A well-written backlog:** Every story had acceptance criteria, and the online-first directive was written into the affected tickets on the day it was given.
- **An early, thorough threat model:** It was finished inside the sprint and has already been useful: it predicted the direct-database risk (T23) that turned out to be a real defect.
- **A strong data foundation:** The schema goes beyond Sprint 1, with row-level security on every table, an audit log and notification triggers. The contract already covers the Sprint 2 review, alert and report features.
- **Fast response to the defect:** The security defect was found, fixed through a proper migration, and checked against the live database within a few hours.
- **Something to show:** The web prototype gives the sponsor and tutor a clickable view of every role, ahead of the real integration.
- **Enforced the agreed workflow:** After multiple github workflow and merge issues, turned on branch protection for main with a required approval and passing CI, required two approvals for changes to the API contract, and name branches after their Jira issue.

3.2 What Could Be Improved

The following actions are proposed for Sprint 2:

- **Integrate early and in small pieces.** Merge to main at least every two days through a reviewed pull request, instead of holding work on long-lived branches until the end of the sprint.
- **Keep Jira in step with the code.** Move an item to In Review only when its pull request is open, and to Done only when it is merged and meets its acceptance criteria. Write the team's Definition of Done into the board.
- **Split large stories.** Break items such as the 13-point CTIP-14 into stories that can be finished on their own, so progress shows on the burndown, and estimate every item, including those added mid-sprint.
- **Unblock the mobile stream first.** With the contract merged, start CTIP-15, CTIP-26 and CTIP-27 at the beginning of Sprint 2, with Patrick and Albian working against the live schema.
- **Check progress mid-sprint.** Review what has been merged at the start of the second week, while there is still time to re-plan.
- **Prioritise the carry-over.** Finish CTIP-36 (test plan) first, since the security assessment starts at the beginning of Sprint 2. Then finish CTIP-14, CTIP-13 (idempotency key) and CTIP-49 (CI and branch protection).

4 Sprint Deliverables

4.1 Current deliverables of Sprint 1

Deliverable	Description	Location	Status
Sprint backlog and board	Stories with acceptance criteria and estimates; on 13 October the large stories were split into stories of at most 3 points (34 new stories, mostly in Sprint 2)	Jira project CTIP (kampungsemuacina.atlassian.net)	Complete
Code repository	Repository structure, README and contribution conventions	GitHub: Kampung-Semua-Cina/CTIP-biodiversitysystem	Complete
Threat model	STRIDE threat model v0.4 with data flow diagram (v4), 25 rated threats, mitigations and test mapping	docs/security/threat-modelling.md, docs/architecture/threat-model-dfd-v4.drawio	Complete (CTIP-18)
API contract	OpenAPI 3.1 specification: 39 paths and 55 operations	packages/api-contract/openapi.yaml	Merged; idempotency key outstanding
Database and storage	Nine Supabase migrations: 16 tables, row-level security, triggers, 3 storage buckets, the 8 October security fix and the role hook for login tokens	supabase/migrations/, applied to the Supabase project	Live; seed data outstanding
ER diagram	Entity-relationship diagram of the Supabase database	docs/architecture/	Complete (CTIP-52)
API service	Express API with Supabase token checks, role checks on all 55 operations and 13 automated tests	services/api	Merged; 2 endpoints built, the rest return 501
Web prototype	React prototype for all four roles, including species catalogue and specimen pages, on sample data	apps/web	Merged; not yet connected to the API
CI workflow	Web lint and build, and API tests, on every pull request and push to main	.github/workflows/ci.yml	In place; not yet a required check

Mobile prototype	Expo SDK 57 app for the Botanist Field App with camera QR scanning, on sample data	apps/mobile	Merged; not yet connected to the API

Table 6: Sprint 1 deliverables

Github Repository: https://github.com/Kampung-Semua-Cina/CTIP-biodiversitysystem

When Sprint 1 was closed in Jira on 14 October 2026, the 10 unfinished stories in Table 4 (27 points) were carried over to Sprint 2.